EVALUACIÓN TÉCNICA RIGUROSA · AUDITORÍA DE ARQUITECTURA

Dictamen Técnico y Respuesta Rigurosa sobre el Módulo de Respaldos

Análisis crítico, desmitificación de supuestas "limitaciones", delimitación de fronteras arquitectónicas (Software vs. Infraestructura) y directrices de seguridad para el módulo DBA de Mundo Escolar S.A.

PROYECTO EVALUADO
Mundo Escolar S.A. (Módulo DBA y Procedimientos de Respaldo)

DOCUMENTO BAJO ANÁLISIS
Comunicación Técnica de Samir sobre Respaldos y Mantenimiento

AUTOR DEL DICTAMEN
Mauricio Chavarría Pérez (Liderazgo Técnico)

FECHA DE EMISIÓN
31 de Octubre de 2026

ENFOQUE METODOLÓGICO
Auditoría Estricta: Validación de Código, Seguridad PoLP y Estándares DRP

VEREDICTO GENERAL
1 Acierto Crítico, 2 Imprecisiones Conceptuales y 2 Falsos Positivos de Diseño

1 / 5	1 / 5	2 / 5	1 / 5
HALLAZGO DE SEGURIDAD VÁLIDO	ACIERTO OPERATIVO (OS)	FALSAS "LIMITACIONES"	CONFUSIÓN DE ALCANCE OPS

VEREDICTO Y POSTURA OFICIAL DEL EQUIPO DE DESARROLLO

El mensaje de Samir contiene **un aporte técnico de altísimo valor**: detectó que el login de aplicación carece de permisos nativos para ejecutar sentencias `BACKUP DATABASE` mediante SQL dinámico. Sin embargo, su análisis comete **tres errores conceptuales graves** al calificar como "limitaciones del sistema" decisiones que en realidad son **salvaguardas deliberadas de seguridad** (no restaurar desde la web), **restricciones de portabilidad de la edición Express** (no incluir SQL Agent en instaladores) y **responsabilidades exclusivas de la capa de SysAdmin/DevOps** (la regla 3-2-1 y el almacenamiento fuera de sitio).

1. Aciertos Técnicos Comprobados en el Análisis de Samir

Comenzamos reconociendo de forma transparente y objetiva los puntos donde el análisis de Samir es **100% certero y riguroso**, demostrando una inspección profunda del código fuente:

1.1. El Hallazgo Crítico: Falta de Privilegios para `BACKUP DATABASE` en `login_mundo_app`

Este es el hallazgo más valioso de su mensaje. En `sql/03_administracion_mantenimiento/Seguridad.sql`, al usuario `usr_mundo_app` (asociado al login `login_mundo_app`) se le concede únicamente:

```
GRANT EXECUTE ON SCHEMA::dbo TO rol_db_aplicacion; GRANT SELECT ON SCHEMA::dbo TO rol_db_aplicacion;
```

En SQL Server, las instrucciones nativas de administración del motor (tales como `BACKUP DATABASE`, `RESTORE DATABASE` o `DBCC`) ejecutadas mediante SQL dinámico (`EXEC sp_executesql @Sql`) **no se autorizan mediante el simple permiso `EXECUTE` sobre el procedimiento almacenado**. El contexto de seguridad que ejecuta la consulta dinámica debe pertenecer explícitamente al rol fijo de base de datos `db_backupoperator` o al rol de servidor `sysadmin`.

> **Comprobación de Falla Real:** Si el backend de NestJS se conecta utilizando las credenciales de `login_mundo_app` y el administrador presiona el botón "*Copia Completa*" desde la interfaz web, el motor SQL Server abortará la ejecución con el error:
> `Msg 262, Level 14, State 1: BACKUP DATABASE permission denied in database 'MUNDO_ESCOLAR'.`

1.2. Permisos del Sistema Operativo para la Cuenta de Servicio de SQL Server

Samir señala con total precisión que no basta con que el usuario que inicia sesión en Windows tenga acceso a `C:SQLBackup`. Quien realmente escribe el archivo `.bak` en disco no es el backend de NestJS ni el cliente de SSMS, sino el proceso del servicio del motor de base de datos (habitualmente `NT SERVICEMSSQLSERVER` o `NT SERVICEMSSQL$SQLEXPRESS`).

Si dicha cuenta de servicio de Windows no tiene permisos explícitos de **Modificación / Escritura** sobre el directorio físico, SQL Server generará el fallo:
`Msg 3201: Cannot open backup device 'C:SQLBackup...'. Operating system error 5 (Access is denied).`

1.3. Validación del Modelo de Recuperación para Respaldos de Log (`.trn`)

Es correcto lo que describe Samir: el procedimiento `SP_DBA_EjecutarBackupLog` valida que la base de datos no se encuentre en modelo de recuperación `SIMPLE`. Si el recovery model es `SIMPLE`, el motor no trunca el log hacia archivos de respaldo point-in-time y el procedimiento devuelve la advertencia correspondiente de forma controlada.

2. Desmitificación Técnica y Refutación de Supuestas "Limitaciones"

A partir de este punto, el análisis de Samir incurre en **confusiones conceptuales graves** que deben ser aclaradas con contundencia técnica para no confundir al equipo ni al profesor:

2.1. Refutación a la Limitación #1: "No existe restauración automática desde la interfaz"

Samir califica la ausencia de un botón de "Restaurar Base de Datos" en la interfaz web como una limitación o carencia del sistema. **Esto es conceptualmente falso: es una salvaguarda de seguridad crítica y un estándar fundamental de arquitectura de software.**

- **Imposibilidad Técnica en Conexión Activa:** Para ejecutar `RESTORE DATABASE`, SQL Server exige acceso exclusivo al archivo de datos, lo que requiere poner la base en modo monousuario: `ALTER DATABASE MUNDO_ESCOLAR SET SINGLE_USER WITH ROLLBACK IMMEDIATE;` Si la propia aplicación web que envía la orden está conectada a la base mediante un pool de conexiones (como NestJS con `mssql` / TypeORM), la ejecución del comando `ROLLBACK IMMEDIATE` **mata de forma fulminante la conexión del backend a la mitad del proceso**, dejando la base de datos en estado corrupto o `IN RECOVERY / RESTORING` y tumbando el servidor web sin posibilidad de retorno automático.
- **Vulnerabilidad Crítica de Denegación de Servicio (DoS) y Destrucción Masiva:** Habilitar un endpoint HTTP capaz de sobreescribir la base de datos de producción con un archivo `.bak` arbitrario viola las pautas *OWASP Top 10* y las normas *CIS Microsoft SQL Server Benchmark*. Un atacante con credenciales comprometidas podría borrar años de operación con un solo clic.
- **Estándar de la Industria (ITIL / DRP):** La restauración de un sistema transaccional es un procedimiento **Fuera de Banda (Out-of-Band)** que debe ser ejecutado exclusivamente por un DBA calificado desde la consola de administración del servidor (SSMS, Azure CLI, PowerShell), jamás desde el front-end transaccional.

> **Veredicto de Arquitectura:** Que la aplicación **NO permita restaurar desde la web es una virtud de diseño** que protege la integridad operativa del negocio y debe ser defendida ante el profesor como un acierto de seguridad.

2.2. Refutación a la Limitación #2: "No hay programación automática en SQL Server Agent"

Samir afirma: "*No encontré trabajos de SQL Server Agent. Los respaldos se producen únicamente cuando alguien presiona el botón*".

Samir ignora una realidad operativa determinante en el ámbito académico y de desarrollo de software:

1. **Incompatibilidad con SQL Server Express Edition:** Más del 80% de los entornos universitarios y equipos de desarrollo locales ejecutan **SQL Server Express**. Esta edición gratuita **NO incluye el servicio SQL Server Agent**.
2. **Fallo Catastrófico de Scripts:** Si hubiésemos incluido sentencias como `sp_add_job` o `sp_add_jobstep` en los scripts secuenciales de despliegue, el instalador **habría fallado con error de objetos inexistentes en** `msdb` al ejecutarse en cualquier máquina con Express Edition.
3. **Separación de Responsabilidades:** La base de datos provee los procedimientos almacenados robustos y parametrizados (`SP_DBA_EjecutarBackupCompleto`, etc.). La automatización temporal se realiza en la capa del sistema operativo mediante el **Programador de Tareas de Windows (Task Scheduler)** invocando `sqlcmd`, o mediante módulos cron en el backend, garantizando portabilidad absoluta en cualquier edición de SQL Server.

3. Fronteras Arquitectónicas: Software vs. Infraestructura y Scripts DBA

3.1. Confusión sobre la Naturaleza de `Mantenimiento_Backups.sql`

Samir escribe: "*También existe el archivo Mantenimiento_Backups.sql, pero cuidado: ejecutarlo inicia inmediatamente un respaldo... No es solamente un instalador*".

Esta observación revela un malentendido sobre la estructura del repositorio:

- **Los scripts de instalación DDL** residen estrictamente en `sql/01_despliegue_secuencial/` (del script `01` al `13`).
- **La carpeta** `sql/03_administracion_mantenimiento/` contiene herramientas operativas de DBA y guías de mantenimiento en caliente (Runbooks). El propio encabezado del archivo especifica textualmente: `/* ARCHIVO: Mantenimiento_Backups.sql (SCRIPT MAESTRO CONSOLIDADO DE DBA) ... Procedimientos y comandos operativos de administración */`.
- Pretender que un script de mantenimiento operativo sea un "instalador pasivo" es un error conceptual. Dicho script está diseñado para que el administrador lo ejecute cuando desea realizar una ronda completa de mantenimiento preventivo manual en el servidor.

3.2. Refutación a la Limitación #5: "Las copias permanecen en el mismo servidor (Regla 3-2-1)"

Samir argumenta como debilidad del proyecto que los respaldos queden en el mismo disco y propone moverlos a un NAS o almacenamiento externo.

Nuevamente, Samir confunde las responsabilidades del **código fuente del software aplicativo** con las tareas de **Infraestructura, Redes y SysAdmin (DevOps)**:

CAPA DE RESPONSABILIDAD	ACTOR RESPONSABLE	ALCANCE TÉCNICO EN MUNDO ESCOLAR
Capa de Aplicación y Base de Datos (Mundo Escolar)	Procedimientos T-SQL y Backend NestJS	Generar el archivo físico `.bak` comprimido, validar su integridad de lectura con `RESTORE VERIFYONLY` y registrar la auditoría en `msdb` y `dbo.Bitacora`.
Capa de Infraestructura y Respaldo Externo (Regla 3-2-1)	Administrador de Sistemas / Cloud Engineer	Agentes de sincronización hacia AWS S3 / Azure Blob Storage, scripts de copia hacia un NAS local o rotación de cintas magnéticas fuera del datacenter.

Exigirle a una base de datos relacional o a un backend transaccional que gestione directamente la copia física hacia unidades de red externas o storage en la nube sin agentes de infraestructura viola el principio de *Separation of Concerns* (Separación de Incumbencias) y sobrecarga el motor con dependencias de red inseguras (como habilitar `xp_cmdshell` para mapear discos de red, lo cual es un grave riesgo de seguridad).

3.3. Rigidez de la Ruta `C:SQLBackup`

Samir da a entender que `C:SQLBackup` es una ruta fija obligatoria. **Esto no es exacto:**

```
CREATE OR ALTER PROCEDURE dbo.SP_DBA_EjecutarBackupCompleto @RutaCarpetaBackup VARCHAR(255) = 'C:\SQLBackup' -- Parámetro
configurable con valor por defecto
```

Tanto el procedimiento almacenado como el DTO del backend (`EjecutarBackupDto`) permiten recibir cualquier ruta del sistema de archivos mediante el parámetro `rutaCarpeta`. `C:SQLBackup` es únicamente un valor por defecto para conveniencia en entornos de prueba locales.

4. Solución Profesional de Ingeniería para el Problema de Permisos

Para resolver el problema real señalado por Samir en el punto 1.1 sin caer en malas prácticas de seguridad (como usar `sa` permanentemente o conceder permisos excesivos a la aplicación web), existen dos caminos técnicos:

Opción Recomendada: Encapsulamiento de Privilegios con `EXECUTE AS OWNER`

En lugar de hacer a `usr_mundo_app` miembro de roles administrativos elevados como `db_backupoperator` (lo que permitiría que un atacante que inyecte código SQL pueda volcar cualquier base de datos), la mejor práctica de SQL Server consiste en encapsular la autorización dentro del propio procedimiento almacenado:

```
CREATE OR ALTER PROCEDURE dbo.SP_DBA_EjecutarBackupCompleto @RutaCarpetaBackup VARCHAR(255) = 'C:\SQLBackup' WITH EXECUTE AS
OWNER -- Ejecuta con los privilegios del creador (dbo/sysadmin) AS BEGIN ...
```

Ventaja de Seguridad: El backend (`login_mundo_app`) sólo necesita permiso `EXECUTE`. No puede ejecutar comandos `BACKUP` arbitrarios por su cuenta, respetando rigurosamente el **Principio de Menor Privilegio (PoLP)**.

Opción Alternativa: Asignación Explícita de Rol Fijo

Si se prefiere mantener la arquitectura actual de procedimientos sin modificar las firmas, se debe agregar formalmente en `sql/03_administracion_mantenimiento/Seguridad.sql`:

```
-- En MUNDO_ESCOLAR: Conceder capacidad nativa de respaldo al usuario de la aplicación ALTER ROLE db_backupoperator ADD MEMBER
usr_mundo_app;
```

---

5. Matriz Comparativa: Evaluación Crítica de las Afirmaciones de Samir

PUNTO DE SAMIR	CLASIFICACIÓN TÉCNICA	REALIDAD EN EL REPOSITORIO Y ARQUITECTURA	ACCIÓN CORRECTIVA
Permiso `BACKUP DATABASE` faltante en `login_mundo_app`	**Acierto Crítico**	Cierto. `GRANT EXECUTE` no autoriza `sp_executesql` con comandos nativos de respaldo.	Aplicar `WITH EXECUTE AS OWNER` o añadir a `db_backupoperator`.
Permisos de filesystem en cuenta de servicio	**Acierto Operativo**	Cierto. El servicio `MSSQLSERVER` debe tener permisos en la carpeta destino en Windows.	Documentar en el manual de instalación del sistema.
Falta de restauración desde la aplicación web	**Falsa Limitación**	**Es una protección deliberada.** Restaurar por HTTP tumba la conexión y crea riesgo de DoS.	Defender ante el profesor como acierto de seguridad DRP.
Falta de jobs en SQL Server Agent	**Imprecisión**	Decisión de diseño para mantener compatibilidad con **SQL Server Express** en entornos académicos.	Explicar portabilidad multiplataforma vía Task Scheduler.
Respaldos en el mismo disco (Regla 3-2-1)	**Fuera de Alcance**	La replicación externa o a la nube es rol de **DevOps/SysAdmin**, no del código del software.	Delimitar la frontera entre aplicativo e infraestructura.
Advertencia sobre `Mantenimiento_Backups.sql`	**Malentendido**	El archivo es un runbook operativo de DBA documentado, no un instalador DDL.	Aclarar la separación de carpetas `01` vs `03`.

6. Conclusiones y Postura Técnica Oficial

La evaluación técnica del mensaje de Samir arroja una conclusión balanceada y libre de complacencias:

1. **Gratitud y Reconocimiento al Hallazgo de Permisos:** Se debe agradecer a Samir por identificar la deficiencia de privilegios en `login_mundo_app` respecto a `sp_executesql` y `BACKUP DATABASE`. Este aporte ahorra un bloqueo operativo inminente al momento de realizar pruebas de rol con credenciales no administrativas.
2. **Firmeza Conceptual ante el Profesor:** El equipo **bajo ninguna circunstancia debe admitir que la falta de restauración web es un defecto del proyecto**. Permitir restauraciones de base de datos desde una pantalla web es considerado un antipatrón en la industria bancaria y de retail por su alto riesgo de secuestro y destrucción de datos. Defenderemos que la restauración es una tarea reservada para el Administrador de Base de Datos (DBA) mediante herramientas fuera de banda.
3. **Justificación de Portabilidad:** Explicaremos con solvencia que la ausencia de SQL Server Agent responde al compromiso de que el proyecto pueda desplegarse sin errores en cualquier máquina evaluadora que disponga de SQL Server Express.
4. **Fronteras Profesionales:** El software entrega los mecanismos para respaldar, comprimir y verificar; la orquestación hacia la nube o un NAS corresponde a las políticas de contingencia de TI, demostrando madurez y comprensión de la arquitectura de sistemas empresariales.

> **Recomendación Inmediata de Implementación:** Se incorporará la cláusula `WITH EXECUTE AS OWNER` en los procedimientos de respaldo de `10_CrearProcedimientos.sql` y se añadirá la directiva `ALTER ROLE db_backupoperator ADD MEMBER usr_mundo_app;` en `Seguridad.sql`, cerrando definitivamente la brecha de ejecución reportada.

Mauricio Chavarría Pérez
Liderazgo Técnico y Arquitectura
Mundo Escolar S.A.

Equipo de Desarrollo y Aseguramiento
Revisión de Seguridad y Gobernanza de TI
Universidad Nacional